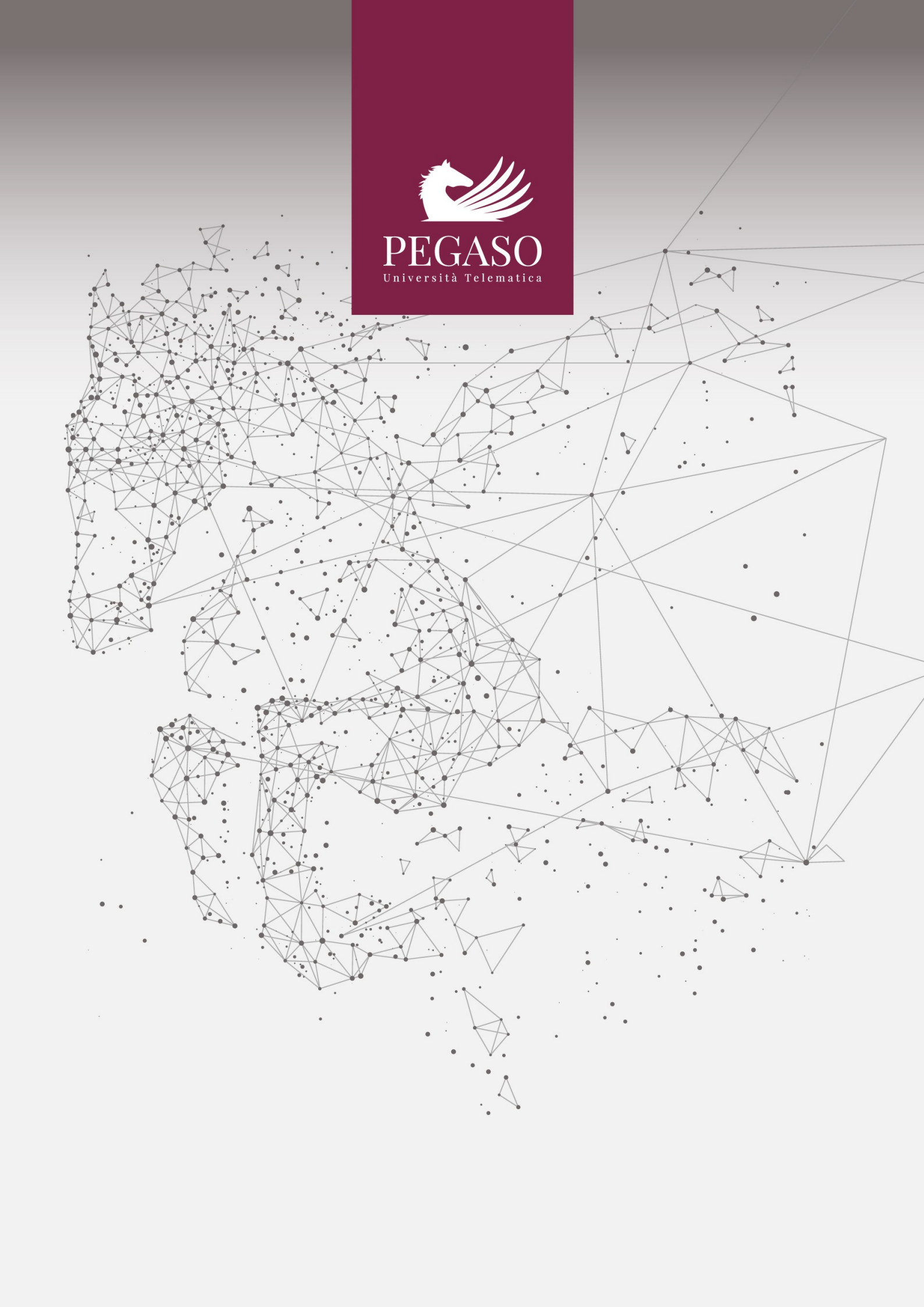

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 REQUISITI PER LE FIRME DIGITALI 3

2 LA FIRMA DIGITALE DIRETTA 5

3 LA FIRMA DIGITALE ARBITRATA 7

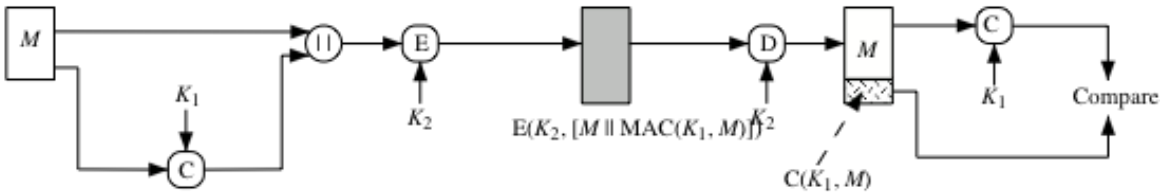
BIBLIOGRAFIA 9

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Requisiti per le firme digitali

Una delle applicazioni più importanti della crittografia a chiave pubblica è senz'altro **la firma digitale**. Infatti l'autenticazione dei messaggi protegge l'utente A e l'utente B nelle loro trasmissioni da una eventuale terza parte (un attaccante) ma non li protegge l'uno dall'altro nel caso di dispute fra di loro.

Per esempio, nel caso di uso della cifratura simmetrica con codice MAC, come nel caso in figura qui sotto, si possono avere due casi di disputa.



- Caso 1: Bob (destinatario) può creare un messaggio e sostenere che proviene da Alice (mittente) utilizzando la loro chiave condivisa.
  - *Nell'esecuzione di un trasferimento elettronico di denaro, il destinatario potrebbe aumentare la somma di denaro sostenendo che è stato il mittente a farlo.*
- Caso 2: Alice (mittente) può negare di aver inviato un messaggio a Bob (destinatario), proprio perché Bob potrebbe averlo creato da solo.
  - *Nell'esecuzione di un acquisto on-line, il mittente dell'ordine potrebbe in seguito negare di averlo fatto.*

La firma digitale serve proprio nel caso in cui non esista completa fiducia fra mittente e destinatario e sia necessario qualcosa di più della semplice autenticazione.

La firma digitale è analoga a quella autografa e deve presentare le seguenti caratteristiche:

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

– deve certificare l'autore e la data/ora della firma.

– deve autenticare il contenuto nel momento in cui viene apposta la firma (include la funzione di autenticazione!)

– deve essere verificabile da terzi al fine di dirimere eventuali dispute

Sulla base delle precedenti caratteristiche, si possono definire i seguenti requisiti per la firma digitale:

– la firma deve dipendere dal messaggio

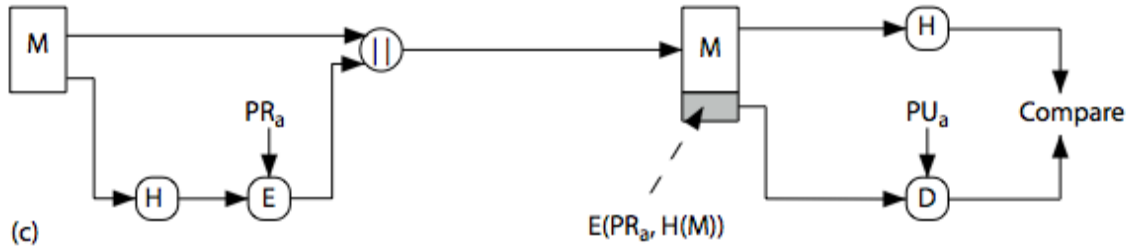
– la firma deve utilizzare informazioni specifiche del mittente (al fine di garantire la non ripudiabilità)

– deve essere facile produrre e verificare la firma digitale

– deve essere computazionalmente impossibile falsificare la firma digitale (dato un determinato messaggio o data una certa firma digitale)

– deve essere possibile conservare una copia della firma digitale

Gli schemi basati su hash sicuri e crittografia pubblica possono garantire tali requisiti (vedi figura):



Esistono fondamentalmente due categorie di approcci per realizzare la firma digitale: la firma digitale **diretta** e la firma digitale **arbitrata**.

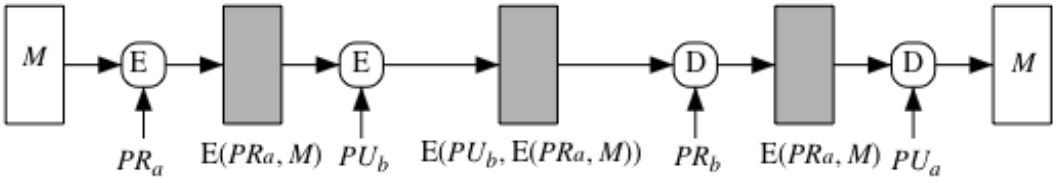
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 La firma digitale diretta

Nel caso di firma digitale **diretta** si ha il coinvolgimento solo del mittente e del destinatario (non ci sono terze parti garanti); il destinatario conosce la chiave pubblica del mittente

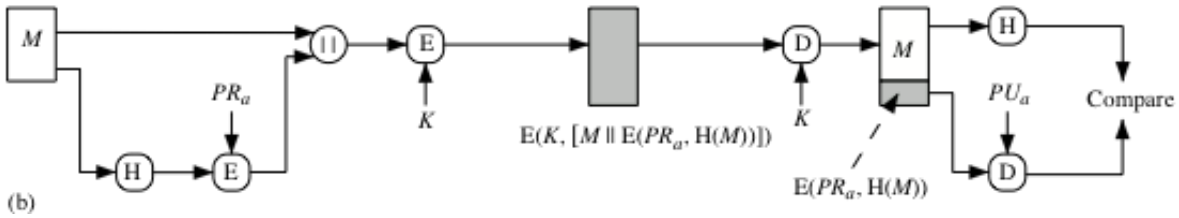
Vediamo due possibili schemi (che garantiscono anche la segretezza del messaggio) realizzati mediante l'uso della crittografia a chiave pubblica o di quella simmetrica

La firma digitale può essere realizzata mediante la crittografia a chiave pubblica, usando anche la chiave pubblica del destinatario per garantire la segretezza del messaggio (vedi figura).



In questa circostanza il messaggio viene cifrato dal mittente A con la propria chiave privata PR_a (firma del mittente A) e poi cifrato con la chiave pubblica PU_b del destinatario al fine di garantire la segretezza del messaggio. Il destinatario decifra i dati ricevuti con la propria chiave privata PR_b (solo lui può farlo!) e poi usa la chiave pubblica PU_a del mittente A per leggere il messaggio cifrato.

La stessa funzionalità di firma digitale può anche essere realizzata con l'uso della crittografia simmetrica per garantire la segretezza del messaggio (vedi figura).



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

In questo caso il mittente A genera un hash del messaggio e lo firma con la propria chiave privata PR_a, poi lo concatena con il messaggio stesso in chiaro e cifra tutto con la chiave segreta K (simmetrica). Dall'altra parte, il destinatario, conoscendo la chiave K condivisa decifra il tutto, poi dalla firma estrae l'hash del messaggio usando la chiave pubblica PU_a del mittente A e rigenerandosi l'hash di M può confrontarli.

In questo caso è verificato il requisito che **la funzione di segretezza sia esterna** cosicché, in caso di disputa, una terza parte possa decodificare il messaggio e verificare la firma.

In entrambi i casi esiste un punto debole che è determinato dalla sicurezza della chiave del mittente, infatti il mittente potrebbe sostenere che tale chiave gli sia stata rubata o che sia stata smarrita, l'inserimento di un timestamp potrebbe aiutare in tal senso in modo da avere un riferimento temporale tra la denuncia del furto/smarrimento e l'invio del messaggio.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 La firma digitale arbitrata

Nella firma digitale arbitrata esiste appunto **un arbitro**. Anche in questo caso esistono vari schemi possibili, l'elemento di base comunque è che il mittente e il destinatario devono avere fiducia che il meccanismo di arbitraggio funzioni correttamente. Sostanzialmente accade che qualsiasi messaggio firmato dal mittente attraversa innanzitutto un arbitro che ne verifica la validità; successivamente il messaggio viene datato e inviato dall'arbitro al destinatario.

Vediamo un esempio di firma digitale arbitrata basata sull'uso della crittografia simmetrica per garantire la segretezza.

- Il mittente X e il destinatario Y condividono la chiave segreta K_{xy}
- L'arbitro A e il mittente X condividono la chiave segreta K_{xa}
- L'arbitro A e il destinatario Y condividono la chiave segreta K_{ay}

- **Dialogo tra il mittente X e l'arbitro A: X→A**

  Il mittente X invia tre quantità concatenate:

  - ID_x identificativo del mittente A
  - $E(K_{xy}, M)$ messaggio cifrato con la chiave condivisa con il destinatario Y
  - $E(K_{xa}, [ID_x \,||\, E(K_{xy}, M)])$ firma del mittente A cifrata con K_{xa}

L'arbitro A decifra la firma con K_{xa} (l'arbitro è in possesso della chiave K_{xa}), quindi verifica l'identificativo e controlla la corrispondenza del messaggio cifrato ma non può leggerlo in quanto non possiede la chiave K_{xy}.

- **Dialogo tra l'arbitro A e il destinatario Y: A→Y**

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

L'arbitro A, verificata la corrispondenza di quanto ricevuto, invia al destinatario Y il seguente messaggio composito tutto cifrato con K_{ay}, (chiave condivisa fra l'arbitro A e il destinatario Y):

- ID_x | | $E(K_{xy}, M)$
- ID_x | | $E(K_{xy}, M)$ | | T questo messaggio cifrato con K_{xa} che costituisce la firma del mittente X, garantita dall'arbitro A in relazione ad un certo timestamp T

T è appunto un timestamp che vincola la firma del mittente ad un certa istante temporale.

A questo punto il destinatario Y, conoscendo appunto K_{ay}, può decifrare il messaggio composito, inviatogli dall'arbitro A e quindi:

- ricavare l'identificativo mittente ID_x
- leggere il messaggio M attraverso l'uso della chiave K_{xy} di cui è in possesso (segreto tra il mittente X e il destinatario Y)
- conservare la firma del mittente X (contenente il timestamp T aggiunto dall'arbitro A) per un'eventuale disputa

Il protocollo è così concluso e tutto funziona…..a meno che non succeda che il ruolo di garante svolto dall'arbitro A non sia svolto correttamente; visto che l'arbitro A possiede entrambe le informazioni segrete di X verso A e di Y verso A (ma non di X verso Y) potrebbe accadere che:

- l'arbitro A potrebbe allearsi con il mittente X negando di avere inviato un messaggio firmato
- l'arbitro A potrebbe allearsi con il destinatario Y per falsificare la firma del mittente X.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitolo 13.*

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).